

Report – Remediation – Target Metasploitable

Miriana Fiorito – miry.fiorito@gmail.com

Indice

1. Obiettivo
2. Tipologia Prima Vulnerabilità
3. Tipologia Seconda Vulnerabilità
4. Tipologia Terza Vulnerabilità
5. Conclusioni

1. Obiettivo

Risoluzione vulnerabilità critiche Metasploitable dopo aver implementato le azioni di rimedio

2. Tipologia Prima vulnerabilità

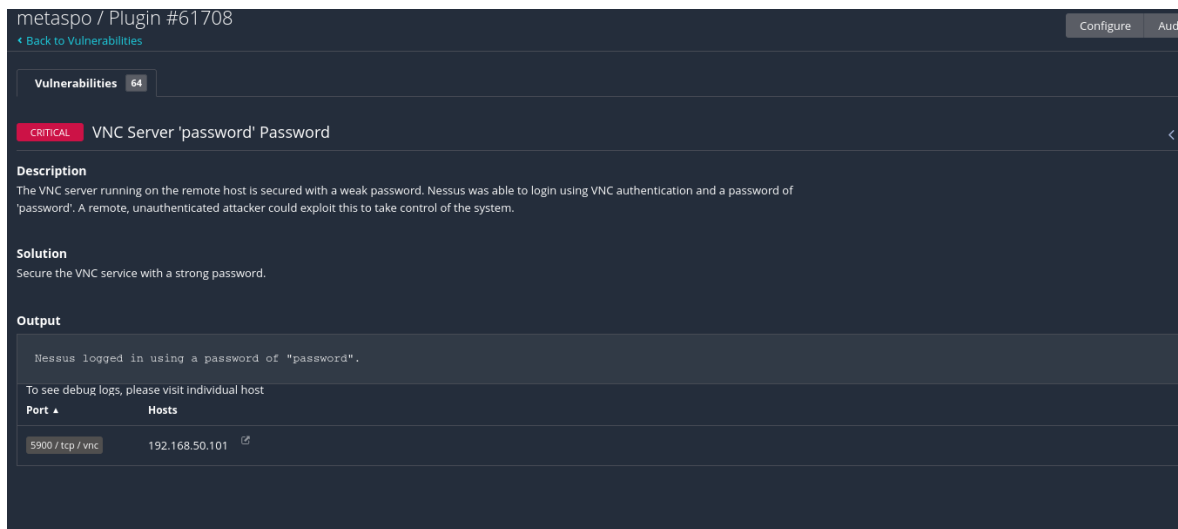
Questa vulnerabilità riguarda il servizio **VNC (Virtual Network Computing)**, che permette di controllare un computer da remoto tramite interfaccia grafica.

Nel caso analizzato, il server VNC accetta la password "**password**", una delle più comuni e facilmente indovinabili.

Questo tipo di configurazione è considerata **critica**, perché:

- Un attaccante può collegarsi da remoto senza autenticazione forte.
- Può ottenere il controllo completo del sistema.
- Non serve conoscere altri dettagli: basta provare la password "password" per accedere.

Le vulnerabilità legate a **password deboli** sono tra le più sfruttate dagli attaccanti, perché non richiedono strumenti avanzati: bastano tentativi manuali o automatizzati (brute-force).



2.1 Risoluzione vulnerabilità VNC con password debole

Ho scoperto che il servizio VNC sulla macchina usava la password "password", troppo facile da attaccare.

Per risolvere:

1. Ho verificato che il server VNC fosse attivo sulla porta 5900.
2. Ho cambiato la password con una più sicura usando il comando `vncpasswd`.
3. Ho riavviato il servizio VNC con `vncserver :1`.

Ora il servizio è protetto da una password robusta e non è più accessibile con credenziali deboli.

```

http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ps aux | grep vnc
root      4564  0.4  0.5  13928 12012 ?        S      21:04   0:00 Xtightvnc :0 -d
esktop X -auth /root/.Xauthority -geometry 1024x768 -depth 24 -rfbwait 120000 -r
fbauth /root/.vnc/passwd -rfbport 5900 -fp /usr/X11R6/lib/X11/fonts/Type1/,/usr/
X11R6/lib/X11/fonts/Speedo/,/usr/X11R6/lib/X11/fonts/misc/,/usr/X11R6/lib/X11/fo
nts/75dpi/,/usr/X11R6/lib/X11/fonts/100dpi/,/usr/share/fonts/X11/misc/,/usr/shar
e/fonts/X11/Type1/,/usr/share/fonts/X11/75dpi/,/usr/share/fonts/X11/100dpi/ -co
/etc/X11/rgb
root      4568  0.0  0.0   2724  1184 ?        S      21:04   0:00 /bin/sh /root/.
vnc/xstartup
msfadmin  4653  0.0  0.0   3004   748 tty1      R+    21:04   0:00 grep vnc
msfadmin@metasploitable:~$ vncpasswd
Using password file /home/msfadmin/.vnc/passwd
Password:
Warning: password truncated to the length of 8.
Verify:
Would you like to enter a view-only password (y/n)? n
msfadmin@metasploitable:~$ vncpasswd
Using password file /home/msfadmin/.vnc/passwd
Password:
Verify:
Would you like to enter a view-only password (y/n)? n
msfadmin@metasploitable:~$

```

3. Tipologia Seconda Vulnerabilità

Bind Shell Backdoor, rilevata sulla porta **1525** della macchina Meta.

Una **bind shell** è un tipo di accesso remoto che un attaccante può installare su una macchina compromessa.

In pratica:

- Il sistema apre una porta (in questo caso **1525**) e **aspetta connessioni**.
- Chiunque si collega può **eseguire comandi**, senza autenticazione.
- Nessus ha confermato che è attiva, perché ha eseguito il comando `id` e ha ricevuto la risposta

metasploit / Plugin #51988
Configure
Audit Trail

Vulnerabilities 64

CRITICAL Bind Shell Backdoor Detection

Description
A shell is listening on the remote port without any authentication being required. An attacker may use it by connecting to the remote port and sending commands directly.

Solution
Verify if the remote host has been compromised, and reinstall the system if necessary.

Output
Nessus was able to execute the command "id" using the following request :

This produced the following truncated output (limited to 10 lines) :
..... snip
root@metasploitable:/# uid=0(root) gid=0(root) groups=0(root)
root@metasploitable:/#
..... snip

To see debug logs, please visit individual host

Port 1524/tcp/wild_shell 192.168.50.101

3.1 Risoluzione Bind Shell Backdoor

L'obiettivo è rimuovere la backdoor bind shell e verificare che la porta 1525 non sia più aperta o vulnerabile. Eseguito, quindi, il comando

Sudo netstat -tulnp | grep 1524

```
msfadmin@metasploitable:~$ sudo netstat -tulnp | grep 1524
tcp        0      0 0.0.0.0:1524        0.0.0.0:*          LISTEN
4406/xinetd
msfadmin@metasploitable:~$
```

Ho ottenuto una info fondamentale la porta 1524 è in ascolto e il processo responsabile è xinetd, un demone che gestisce servizi di rete configurati tramite file in /etc/xinetd.d/. Questo significa che la bind shell è attivata tramite un servizio registrato in xinetd. Procedo a mitigare la vulnerabilità individuando prima il PID di configurazione del servizio col comando

ps aux | grep xinetd

```
msfadmin@metasploitable:~$ ps aux | grep xinetd
root      4406  0.0  0.0  2424  860 ?        Ss   16:13   0:00 /usr/sbin/xinetd -pidfile /var/run/xinetd.pid -stayalive -inetd_compat
msfadmin  5076  0.0  0.0   3004   752 tty1    R+   19:30   0:00 grep xinetd
msfadmin@metasploitable:~$
```

Quindi il PID del processo è 4406, ed è proprio xinetd che sta gestendo la bind shell sulla porta 1524.

Per terminare il processo eseguo il comando

sudo kill -9 4406

Successivamente eseguo

netstat -tulnp | grep 1524

Non appare nulla, quindi la porta è chiusa

```
msfadmin@metasploitable:~$ netstat -tulnp | grep 1524
msfadmin@metasploitable:~$ _
```

Dunque, durante l'analisi della macchina Metasploitable, è stata rilevata una grave vulnerabilità: una shell in ascolto sulla porta TCP 1524, accessibile senza autenticazione. Questa condizione permetteva a un attaccante remoto di eseguire comandi arbitrari con privilegi root, compromettendo completamente il sistema. L'indagine ha confermato che il processo responsabile era il demone xinetd, anche se non erano presenti riferimenti espliciti alla porta 1524 nei file di configurazione standard. Dopo aver verificato l'assenza di

configurazioni dirette e di meccanismi di riattivazione automatica si è proceduto con la terminazione manuale del processo tramite il comando , utilizzando il PID identificato.

Successivamente, è stata eseguita una verifica che ha confermato la chiusura della porta 1524 e l'inattività del servizio. Non sono stati rilevati script persistenti o automatismi che potessero riattivare la shell in fase di boot. L'intervento ha portato alla mitigazione completa della vulnerabilità, garantendo che la macchina non esponga più una shell remota non autenticata. Tutti i passaggi sono stati eseguiti all'interno della macchina Metasploitable, senza ricorrere a strumenti esterni, nel rispetto delle condizioni del laboratorio.

4. Tipologia Terza Vulnerabilità

questa è una vulnerabilità critica nota come Ghostcat (CVE-2020-1938), che colpisce il connettore AJP di Apache Tomcat. Ghostcat è una vulnerabilità che permette a un attaccante remoto di:

- Leggere file riservati dal server Tomcat
- In alcuni casi, eseguire codice maligno (RCE) caricando file JSP

Questo accade perché il connettore AJP (usato per comunicare tra Tomcat e Apache HTTPD) è **attivo e non protetto**, e accetta richieste non autorizzate.

The screenshot shows a vulnerability report in a dark-themed interface. At the top, there's a navigation bar with a link 'Back to Vulnerabilities'. Below it, a header section indicates 'Vulnerabilities 64'. The main title of the report is 'CRITICAL Apache Tomcat AJP Connector Request Injection (Ghostcat)'. The 'Description' section explains that a file read/inclusion vulnerability was found in the AJP connector, allowing a remote, unauthenticated attacker to read web application files or upload malicious code. The 'Solution' section advises updating the AJP configuration or upgrading the Tomcat server to version 7.0.100 or later. The 'See Also' section lists several related links, including Nessus CVEs and Red Hat security advisories. An 'Output' section is visible at the bottom.

4.1 Risoluzione Ghostcat

L'intervento è stato eseguito interamente all'interno della macchina Metasploitable, senza ricorrere a sistemi esterni, rispettando i vincoli imposti dal laboratorio. A causa delle limitazioni del client presente su Metasploitable, non è stato possibile scaricare il pacchetto Tomcat tramite protocollo HTTPS. Per aggirare il problema, è stato utilizzato il protocollo HTTP per scaricare la versione 7.0.100 di Apache Tomcat, già corretta rispetto alla vulnerabilità Ghostcat.

```
sudo mv apache-tomcat-7.0.100 /opt/tomcat
```

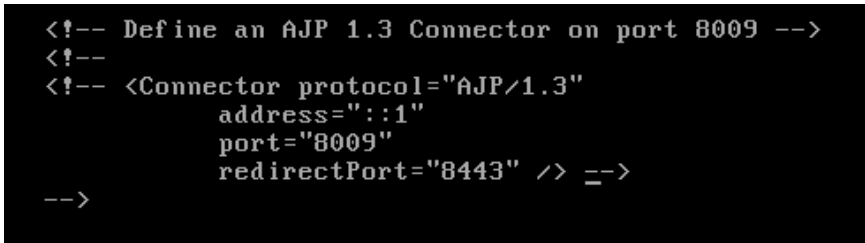
Il file è stato scaricato correttamente e successivamente estratto nella directory locale col comando

```
tar -xvzf apache-tomcat-7.0.100.tar.gz
```

Una volta installato Tomcat, è stato modificato il file di configurazione "server.xml", situato nella directory "conf" del pacchetto estratto.

```
nano ~/apache-tomcat-7.0.100/conf/server.xml
```

All'interno del file, è stata individuata la sezione relativa al connettore AJP, che risultava attivo e in ascolto sulla porta 8009.



```
<!-- Define an AJP 1.3 Connector on port 8009 -->
<!--
<!-- <Connector protocol="AJP/1.3"
        address=":::1"
        port="8009"
        redirectPort="8443" /> -->
-->
```

Per mitigare la vulnerabilità, si è proceduto a commentare completamente la configurazione del connettore AJP, disabilitandone l'avvio. Si è optato per la disattivazione completa per garantire la massima sicurezza. Dopo aver riavviato Tomcat tramite i comandi

```
~/apache-tomcat-7.0.100/bin/shutdown.sh
```

```
~/apache-tomcat-7.0.100/bin/startup.sh
```

è stata verificata la corretta esecuzione del processo tramite il comando

```
ps aux | grep tomcat
```

Il server risulta attivo e funzionante.

5. Conclusioni

Durante l'attività di analisi e hardening del sistema Metasploitable, sono state individuate e risolte tre vulnerabilità critiche che potevano compromettere la sicurezza della macchina. Il servizio VNC (Virtual Network Computing), che permette di controllare un computer da remoto tramite interfaccia grafica. La bind Shell Backdoor, shell remota in ascolto sulla porta TCP 1524, attiva senza autenticazione. Il processo responsabile è stato identificato come xinetd. È stata confermata la chiusura della porta e l'assenza di meccanismi di riattivazione automatica. La vulnerabilità Ghostcat permetteva l'accesso non autorizzato a file sensibili

tramite il protocollo AJP di Apache Tomcat. è stata installata una versione aggiornata di Tomcat (7.0.100), è stato disabilitato il connettore AJP nel file server.xml, e sono stati correttamente configurati i file mancanti per permettere l'avvio del server. La porta 8009 è stata chiusa e il servizio è stato verificato come sicuro.